

Cyber Tabletop Exercise

Nonprofit Donation Fraud — Compromised Fundraising Mailbox

Facilitator-ready exercise package generated from STIX 2.1 bundle: **Nonprofit Donation Fraud TTX**

Organization	International Humanitarian Nonprofit
Sector	Nonprofit / charity
Scenario type	Business email compromise, donor payment redirection, donation fraud
Recommended duration	75–90 minutes plus 15-minute hot wash
Primary audience	Executive leadership, fundraising/donor relations, finance, legal/privacy, communications, IT/security operations
Exercise date	To be scheduled by facilitator

Confidential exercise document. For internal planning, facilitation, and authorized participant distribution only.

1. Agenda

- Welcome, introductions, roles, and rules of engagement
- Exercise objectives and scope
- Scenario background and assumptions
- Four phased injects with facilitated discussion
- Decision points, expected actions, and cross-functional escalation
- Debrief, lessons learned, action tracking, and MITRE ATT&CK mapping

Recommended timing: 10 minutes introduction, 55–65 minutes inject discussion, 15 minutes debrief and action capture.

2. Exercise Objectives

- Validate the nonprofit's ability to detect, triage, escalate, and contain a compromised fundraising mailbox during an active campaign.
- Exercise decision-making across fundraising, donor relations, finance, communications, legal/privacy, IT, and leadership.
- Assess fraud response processes for payment redirection affecting donors and expected donations.
- Test clarity of donor notification, fraud guidance, public messaging, and reputation management.
- Identify control gaps in email security, privileged mailbox monitoring, payment instruction governance, and donor verification workflows.

3. Scope and Audience

This exercise focuses on a fictional but realistic cyber-enabled fraud incident in which an attacker compromises a fundraising mailbox and uses forwarding rules and fraudulent payment instructions to redirect donors. The exercise does not test live technical systems and does not require production access.

In scope	Incident command, escalation, donor communications, finance reconciliation, mailbox investigation, fraud containment, legal/privacy assessment, regulatory/contractual considerations, and lessons learned.
Out of scope	Hands-on forensics, live containment actions, real donor outreach, real media engagement, and attribution beyond available evidence.
Success criteria	Participants identify the incident owner, protect donors from further fraud, preserve evidence, reconcile financial impact, coordinate external messaging, and capture actionable improvements.

4. Rules of Engagement

- This is a no-fault learning exercise; there are no perfect answers.
- Real incidents and safety priorities take precedence.
- Participants should respond according to their real roles, authorities, and documented processes.
- Do not fight the scenario; clarify assumptions and continue decision-making with the information available.
- The facilitator may withhold information until the appropriate inject to preserve realism.
- Capture decisions, open questions, control gaps, and action owners throughout the exercise.

5. Scenario Narrative

The International Humanitarian Nonprofit is running a high-visibility fundraising campaign supporting urgent field operations. Donors interact with the organization through a shared fundraising mailbox, donor relationship managers, and published donation channels. During the campaign, several donors receive unusual payment instructions that appear to come from the nonprofit's fundraising team. The instructions reference active campaign details and request payment to a new account or payment link.

The scenario evolves from donor reports, to discovery of a forwarding rule, to finance confirmation that expected donations did not arrive, and finally to donor outreach and reputation management. The core tension is balancing speed, evidence preservation, donor protection, financial reconciliation, legal/privacy obligations, and public trust.

Assumption for facilitation: the mailbox is cloud-hosted; multi-factor authentication is enabled for most users but not uniformly enforced for shared/service mailboxes; donor payment instructions can be sent by email under certain campaign workflows; and some large donors use manual bank transfer processes.

6. Participant Roles and Expected Perspectives

Role	Perspective to exercise
Executive / Incident Sponsor	Sets risk appetite, confirms crisis activation, approves external messaging and donor remediation posture.
Fundraising / Donor Relations	Validates donor reports, pauses risky workflows, prepares donor-specific outreach, protects relationship trust.
Finance / Treasury	Reconciles expected vs. received donations, identifies fraud exposure, coordinates with banks/payment processors.
IT / Security Operations	Investigates mailbox access, forwarding rules, sign-in logs, compromise indicators, and containment steps.
Legal / Privacy / Compliance	Assesses notification duties, law enforcement engagement, privacy implications, evidence preservation, and donor claims.
Communications	Develops internal, donor, partner, and public messaging; manages media and reputational impact.
Field / Program Operations	Assesses downstream impact if donation delays affect mission delivery commitments.

7. Exercise Timeline Overview

Time	Inject	Development
T+0 / Mon 09:15	Inject 1	Donors report suspicious payment instructions.
T+2h / Mon 11:15	Inject 2	IT discovers external forwarding rule on fundraising mailbox.
T+6h / Mon 15:30	Inject 3	Finance identifies expected donations that never reached the official account.
T+1 day / Tue 10:00	Inject 4	Donor communications, fraud guidance, and reputation management are required.

8.1 Inject 1 — Donor Reports Suspicious Instructions

Exercise time: Monday, 09:15 — campaign day 3

STIX source content: Multiple donors report receiving unusual payment instructions during the fundraising campaign.

Scenario update

Donor relations receives calls and emails from three donors asking whether the nonprofit recently changed payment instructions. One major donor forwarded an email that appears to come from the fundraising mailbox, references the active campaign, and includes a new payment account. The donor has not yet sent funds. A second donor says they already followed the instructions.

What participants know at this stage

- At least three donors received suspicious instructions.
- The message appears to originate from a legitimate fundraising mailbox.
- The campaign is active and time-sensitive.
- There is no confirmed technical compromise yet.

Discussion questions

- Who owns initial triage and who must be informed immediately?
- Do you pause donation instructions or campaign outreach while validating the report?
- How do you verify legitimate payment channels with donors without amplifying panic?
- What evidence should be preserved from donors and internal systems?

Expected actions / good practice indicators

- Open an incident record and assign an incident lead.
- Notify fundraising leadership, IT/security, finance, legal/privacy, and communications.
- Preserve donor emails with headers, timestamps, sender/recipient details, links, and bank/payment details.
- Issue a controlled internal advisory to stop sending manual payment changes until validated.
- Prepare a donor verification script and escalation path for suspected fraud payments.

Facilitator notes

Watch for whether the group treats this as both a cyber incident and a fraud/reputation event. Encourage concrete ownership: donor-facing lead, technical lead, finance reconciliation lead, and decision-maker.

8.2 Inject 2 — Forwarding Rule Found

Exercise time: Monday, 11:15 — 2 hours after first report

STIX source content: IT discovers a mailbox forwarding rule that redirects fundraising correspondence to an external account.

Scenario update

IT reviews the fundraising mailbox and finds a recently created forwarding rule sending copies of messages containing donation-related keywords to an external email account. Sign-in logs show one successful login from an unusual geography overnight. The mailbox is still receiving campaign traffic.

What participants know at this stage

- An unauthorized forwarding rule exists.
- Atypical sign-in activity occurred.
- The attacker may have seen donor correspondence and campaign context.
- The full scope of access is not yet known.

Discussion questions

- What containment actions are safe to take immediately?
- Who approves disabling the mailbox, revoking sessions, resetting credentials, and removing forwarding rules?
- How do you preserve evidence before changing the mailbox state?
- What additional mailboxes, shared drives, CRM records, or payment systems should be checked?

Expected actions / good practice indicators

- Disable/remove the malicious forwarding rule after preserving evidence.
- Revoke active sessions, reset credentials, enforce MFA, and review mailbox delegates and OAuth/app consents.
- Export relevant audit logs and preserve message trace data.
- Search for similar rules across fundraising, finance, executive, and donor relations mailboxes.
- Escalate severity based on donor exposure and potential financial loss.

Facilitator notes

Correct unrealistic decision flow if needed: the technical team should recommend and execute containment under incident authority, while leadership/legal/comms are informed and approve risk-sensitive business impacts.

8.3 Inject 3 — Missing Donations Identified

Exercise time: Monday, 15:30 — 6 hours after first report

STIX source content: Finance identifies donations that were expected but never reached the official donation account.

Scenario update

Finance compares campaign pledges, donor confirmations, and bank/payment processor records. Several expected donations have not arrived, including two high-value transfers. One donor confirms they wired funds to the account in the fraudulent instructions. The bank may still be able to attempt a recall if action is taken quickly.

What participants know at this stage

- At least one donor likely sent funds to a fraudulent destination.
- The financial exposure is still being quantified.
- Donation delays could affect campaign reporting and program commitments.
- Potential personal donor information may have been exposed through email contents.

Discussion questions

- Who contacts the donor, the nonprofit's bank, receiving bank/payment processor, and law enforcement?
- What threshold triggers crisis leadership, board notification, or insurer notification?
- How do you reconcile donor intent, financial loss, and receipting obligations?
- What legal/privacy notification analysis is required?

Expected actions / good practice indicators

- Create a finance reconciliation tracker for affected, suspected, and unaffected donations.
- Initiate bank recall/fraud procedures immediately for known fraudulent transfers.
- Engage legal/privacy to assess donor data exposure and notification requirements.
- Prepare executive and board briefings with confirmed facts, unknowns, and decision needs.
- Document all donor contact, financial recovery steps, and evidence preservation actions.

Facilitator notes

Push participants to separate confirmed facts from assumptions. Ask how they avoid double-counting donations, issuing incorrect tax receipts, or making promises before recovery options are known.

8.4 Inject 4 — Donor Communications and Reputation Management

Exercise time: Tuesday, 10:00 — next business day

STIX source content: Donor relations prepares outreach, fraud guidance, and reputation-management messaging.

Scenario update

A donor posts on social media that the nonprofit's campaign may be compromised. A journalist contacts the communications team asking whether donor funds were stolen. Several donors are asking whether they should cancel donations. Leadership wants to continue the campaign but avoid further harm.

What participants know at this stage

- The mailbox compromise has been contained but investigation continues.
- Some donor communications were likely accessed or redirected.
- Financial impact is not fully final.
- Public trust and campaign momentum are at risk.

Discussion questions

- What message do you send to donors, staff, partners, and the public?
- Who approves external statements and donor-specific fraud guidance?
- Do you disclose payment redirection before final financial numbers are known?
- What longer-term remediation and assurance steps should be communicated?

Expected actions / good practice indicators

- Send targeted donor guidance confirming official payment channels and warning against changed instructions.
- Coordinate a holding statement with communications, legal, executive leadership, fundraising, and IT/security.
- Maintain a single source of truth for donor FAQs, call scripts, and status updates.
- Define criteria for regulatory, privacy, law enforcement, insurance, and board notifications.
- Launch post-incident improvements: payment-change verification, mailbox monitoring, phishing-resistant MFA, donor callback controls, and campaign communications review.

Facilitator notes

Evaluate whether the group protects trust without over-disclosing unverified details. Encourage specific approvals, spokesperson assignment, and consistent messaging across donor relations and public channels.

9. Decision Points and Escalation Triggers

Decision point	Recommended trigger / guidance
Incident classification	Treat as cyber-enabled fraud with possible donor data exposure once mailbox misuse or forwarding is confirmed.
Containment authority	Technical containment should be executed by IT/security under incident authority; business owners approve donor-facing disruption where needed.
Crisis activation	Activate crisis leadership if confirmed financial loss, major donor impact, media attention, legal notification risk, or mission delivery impact exists.
Donor outreach	Use targeted donor outreach first where affected donors are identifiable; broader campaign advisory may be required if exposure scope is unclear.
Law enforcement / bank fraud	Engage quickly when fraudulent transfer is confirmed or suspected; speed affects recovery options.
Public statement	Use a holding statement when media/social attention exists before full facts are known; do not speculate on attribution or final loss.

10. Technical and Business Impacts to Explore

- Technical: unauthorized mailbox rule, possible credential compromise, session/token abuse, external forwarding, mailbox audit log preservation, and scope search across adjacent mailboxes.
- Financial: misdirected donations, delayed campaign reporting, potential recovery attempts, donor receipting complexity, and bank/payment processor coordination.
- Legal/privacy: donor personal information in email, breach notification analysis, evidence preservation, insurer notification, law enforcement reporting, and contractual obligations.
- Operational: donor support surge, fundraising workflow pause, field program funding uncertainty, leadership reporting, and board oversight.
- Reputational: donor confidence, social media amplification, media inquiry response, partner concerns, and assurance messaging.

11. Hot Wash and Lessons Learned

- What decisions were made quickly and confidently?
- Where did ownership, authority, or escalation become unclear?
- Which donor-facing messages were approved, by whom, and using what facts?
- What controls could have prevented or detected the attack earlier?
- What evidence was required but difficult to obtain?
- What policy, playbook, training, monitoring, or technical improvements should be assigned?

Action tracking template

Finding	Owner	Priority	Due date

12. MITRE ATT&CK Mapping

The mapping below reflects techniques represented or strongly implied by the scenario. It is intended for discussion and control validation, not attribution.

Tactic	ID	Technique	Scenario relevance
Initial Access / Persistence / Defense Evasion	T1078.004	Valid Accounts: Cloud Accounts	Use of a compromised cloud-hosted fundraising mailbox account to access donor correspondence and perform mailbox actions.
Collection	T1114.003	Email Collection: Email Forwarding Rule	Creation of a forwarding rule to redirect fundraising correspondence to an external account.
Collection	T1114.002	Email Collection: Remote Email Collection	Remote access to mailbox contents through a cloud email service using compromised credentials or sessions.
Credential Access / Defense Evasion	T1550.001	Use Alternate Authentication Material: Application Access Token	Potential session/token persistence should be considered during investigation of cloud mailbox compromise.
Command and Control / Exfiltration	T1567.002	Exfiltration to Cloud Storage	External forwarding of donor correspondence to an attacker-controlled mailbox or cloud destination is analogous to exfiltration over web/cloud services.
Impact	T1657	Financial Theft	Fraudulent payment instructions cause donors to send funds to attacker-controlled destinations.

Reference basis: MITRE ATT&CK Enterprise techniques for Email Forwarding Rule (T1114.003), Valid Accounts / Cloud Accounts (T1078.004), Remote Email Collection (T1114.002), and related detection strategies for email forwarding rule abuse and valid account use.

13. Glossary

Term	Definition
BEC	Business Email Compromise; fraud enabled by abuse of trusted email accounts or identities.
Donor payment redirection	Unauthorized change to payment instructions intended to route funds to an attacker.
Forwarding rule	Mailbox rule that automatically sends messages to another address; can be abused to monitor correspondence.
MFA	Multi-factor authentication.
SOC	Security Operations Center.
STIX	Structured Threat Information Expression; a standardized format for cyber threat intelligence.

14. Source STIX Summary

Input bundle: bundle--cba08132-9bd4-4e95-a2e6-38c8d89f7c8f6. Incident: Nonprofit Donation Fraud TTX. Identity: International Humanitarian Nonprofit. Four note objects were transformed into staged injects and enriched with facilitation context, expected actions, and ATT&CK mapping.